

HUM 4747: Legal Issues and Cyber Law

Cybersecurity Controls and Human Factors

Aashnan Rahman

BSc in SWE
Islamic University of Technology (IUT)

Winter 2024-2025

① Cybersecurity Control Types

- Physical Controls

- Technical Controls

- Procedural Controls

- Legal Controls

② Human Factors in Cybersecurity

- Knowledge & Training Gaps

- Culture & Organizational Issues

- Trust, Accountability & Procedures

- Social Engineering

③ Connecting Controls to Legal Compliance

④ Summary & Discussion

The Four Pillars of Cybersecurity Controls

We know **what** to defend (via information classification) and **where** to defend it (cyber defense points). Now: **how** to defend it.

1. Physical

Locks, cameras, access cards, secure rooms

2. Technical

Encryption, firewalls, access control lists

3. Procedural

Policies, approval workflows, checklists

4. Legal

Laws, regulations, compliance, penalties

Key Principle

Maintaining technical controls alone will NOT result in effective cybersecurity. All four categories must work together.

Physical Security Controls

Definition

Physical security — measures designed to **deter, prevent, detect, or alert** unauthorized real-world access to a site or material item.

Examples:

- Locked server rooms
- Biometric access (fingerprint, retina)
- Security cameras (CCTV)
- Visitor logs and badges
- Secure disposal of hardware

Why It Matters:

- Your **server rack** is only as secure as the room it's in
- A stolen **hard drive** bypasses all software security
- USB drops can deploy malware
- Data centers need **physical access control**

Rule

Without physical security, all other controls become less relevant. If someone can physically access your equipment, they can bypass technical defenses.

Real-World Example: The Unlocked Network Cupboard

Audit Finding

A research site with 100+ employees had its **entire building network** managed from an **unlocked cupboard** in the main, open, **unmanned lobby** — propped open with a cardboard box to keep it cool.

Consequences:

- Anyone could walk in off the street, **unchallenged**
- Pulling out 2 wires would **stop all 100 people from working**
- Plugging a device into the network would **bypass all technical defenses**

Lesson

Almost all technical controls are ineffective if physical access can be gained to restricted equipment.

Technical Security Controls

Definition

Technical control — the use of an electronic or digital method to influence or command how a digital device **can or cannot be used**.

Examples for Software Engineers:

- **Encryption** — Data at rest and in transit
- **Access Control Lists (ACLs)** — Who can access what
- **Firewalls** — Network traffic filtering
- **Multi-Factor Authentication (MFA)**
- **DLP** — Data Loss Prevention tools

In Your Daily Work:

- SSH keys for Git access
- Role-Based Access Control (RBAC) in your app
- HTTPS / TLS for APIs
- Input validation and sanitization
- Disabling copy-paste on sensitive fields

*If I encrypted data on a memory card, that is a technical control. It may not prevent theft, but it **prevents information exposure**.*

Procedural Security Controls

Definition

Procedural control — an instruction during a sequence of required steps to limit how something **is or is not permitted** to be used.

Examples:

- Requiring **2 authorized approvals** for any access request
- **Code review** before merging to production (PR approvals)
- **Change management** processes for deployments
- **Incident response** procedures
- **Onboarding/offboarding** checklists for employees
- **Backup verification** schedules

Software Team Example

A mandatory **2-person code review** before any merge to main is a procedural control that prevents both accidental bugs and intentional backdoors.

Definition

Legal control — the use of **legislation** to promote positive security methods and to **deter, punish, and correct** infringements.

Examples:

- **GDPR** (EU) — Data protection with fines up to €20M or 4% of global revenue
- **ICT Act 2006** (Bangladesh) — Digital security and e-commerce
- **Digital Security Act 2018** (Bangladesh) — Cybercrime penalties
- **HIPAA** (USA) — Healthcare data protection
- **PCI-DSS** — Payment card security standard

Practical Impact

Companies often pass legal financial responsibilities onto **employees and suppliers** as incentives. Breach of legal controls typically results in **disciplinary action**.

Control Types — Summary

Control	Purpose	SWE Example	If Missing
Physical	Prevent unauthorized physical access	Locked server room, secure disposal	Hardware theft, USB attacks
Technical	Electronic/digital protection	Encryption, MFA, firewalls	Data breaches, MITM attacks
Procedural	Process-based limitations	Code review, change management	Human error, insider threats
Legal	Legislation and compliance	GDPR, ICT Act, NDAs	Fines, lawsuits, criminal charges

Remember

Each time a **new type of information** is identified, the assets and mechanisms it travels through must also be identified, and appropriate controls applied across **all four categories**.

People: The Weakest Link

Core Insight

Although security improves in response to evolving threats, there remains one consistent way to bypass it — **compromise or misuse the valid access of an authorized user**.

Even a fully secured transaction can be bypassed by **influencing the authorized individual** to perform actions on the attacker's behalf.

The 7 most significant human factors:

- ① Inadequate cybersecurity knowledge
- ② Poor risk capture and communication
- ③ Culture and relationship issues
- ④ Under-investment in security training
- ⑤ Using trust instead of procedures
- ⑥ Absence of single point of accountability
- ⑦ Social engineering

Inadequate Cybersecurity Knowledge

- Cybersecurity is **not static** — it requires **continuous learning**
- Emerging technologies **continuously create** new vulnerabilities
- Even cybersecurity specialists spend ~30% of their time on **learning**

Common Mistake

Organizations hire a small number of **expensive specialists** but then deprive them of **training time** to keep their knowledge current.

The Training Paradox

*“The only thing more dangerous than training a cybersecurity employee who may then leave is **not training** the employee and having them stay.”*

Under-Investment in Security Awareness

The Password Problem

At a cybersecurity lecture packed with security specialists, only ~**20%** maintained separate username/password for every account. One person: “325 and counting.”

Practical Security Awareness for Software Teams:

- **Don't leave devices unlocked** when not in use
- **Don't click suspicious links** — malware installs with one click
- Use **different passwords** for different accounts
- Be aware of **shoulder surfing** in co-working spaces

Good Training

Security awareness training should be **concise, relevant, useful, thought-provoking, and frequent**. Updated at least **once per year**.

Poor Risk Capture & Communication

People often **notice risks** but **don't report** them. Three main reasons:

- ① **Silo thinking** — “It doesn't affect my department/budget”
- ② **Negative consequences** — Reporting risks can hurt your career in some organizations
- ③ **Poor escalation processes** — Reported risks get buried rather than managed

Solution

Organizations that **actively encourage** staff to identify and report risks into a **structured, formal risk management framework** will create a more informed and less vulnerable enterprise.

For Software Teams

A well-implemented **bug bounty program** or **security issue tracker** with clear escalation paths encourages risk reporting.

Culture and Relationship Issues

Positive Culture = Better Security

Organizations with an employee-oriented culture that values **effective teamwork** tend to have **fewer security gaps**. When problems emerge, people bring them up and sort them out.

Negative Culture = Insider Threats

- Disaffected employees are more likely to **exploit their access**
- Overworked teams **bypass security controls** for convenience
- Lack of whistleblower protection discourages **reporting vulnerabilities**
- A 5-minute conversation with a disgruntled employee can reveal enough to **plan a cyber attack**

*“In my experience, an enterprise with a negative culture will be **riddled with security gaps** and people ready to help expose them.”*

Using Trust Instead of Procedures

The Problem

In growing organizations, a few trusted individuals enjoy **unbridled privileges**. “They’ve always been trustworthy” — until one day, they aren’t.

Edward Snowden

Worked as a “safe pair of hands” in government security for years. Had trusted access to classified systems. Used that trust to exfiltrate **thousands of classified documents** from the NSA.

Principle

At any point involving **privileged access**, procedures must ensure **no one can independently act based on trust alone**. Even CISOs should not have **direct, unmonitored access** to the security infrastructure they protect.

Single Point of Accountability (SPOA)

Definition

The principle that all critical assets, processes, and actions must have **clear ownership and traceability to a single person**.

Single Accountability ✓

- Clear ownership
- Proven to work in highly regulated systems
- Accountability drives action

Shared Accountability ✗

- Unclear responsibility
- “Not my job” mentality
- In failure: equally *unaccountable*

In Software Teams

Every microservice, database, and deployment pipeline should have a **designated owner**. If a security incident occurs, there's a clear point of contact.

Social Engineering — The Art of Manipulation

Definition

Social engineering is the art of **manipulating people** through personal interaction to gain unauthorized access to something.

*“It constantly surprises me that it is so much easier to steal information by **exploiting social situations** than through direct attack.”*

Methods:

- **Pretexting** — Creating a fabricated scenario to extract information
- **Phishing / Spear Phishing** — Targeted deceptive emails
- **Tailgating** — Following authorized personnel into secure areas
- **Baiting** — Leaving infected USB drives in public areas
- **Elicitation** — Casual conversation to extract info (e.g., at a bar)

Social Engineering — Real-World Example

The Case of Bob the Security Guard

Bob was the only security guard in a lobby of a building with **1,000 employees**. The access gate was too slow, so Bob would **manually buzz people in** when they said “Hey Bob.”

Bob probably had **no idea who most of them were**. Perhaps he knew a few hundred.

Social Engineering Questions:

- ① If someone told you this story at a bar and where they worked, could you **get into their building**?
- ② If you visited the lobby once for a legitimate reason, would you **notice this security gap**?

Key Takeaway

Many attacks are **crimes of opportunity**. The wrong information passed to the wrong person at the wrong time can facilitate an attack — even without premeditation.

Detecting Human Factors in Security Failures

Root Cause Analysis — Human Factors Checklist

After any security incident, ask:

- ① Were there **gaps in procedures** that should have been in place?
- ② Were there **risks known** to some but not reported or managed?
- ③ Were there **disinterested or disaffected personnel** involved?
- ④ Was there a **lack of security awareness** among people involved?
- ⑤ Was there **access privilege not adequately monitored** or segregated?
- ⑥ Was there any form of **social manipulation** to gain access?

Body Language Audit Technique

An experienced auditor can identify security gaps by watching **body language** during interviews. When discomfort appears — that's where to dig deeper.

From Controls to Compliance

The Connection

Legal/regulatory requirements **mandate** that organizations implement appropriate controls. Failure to do so results in **legal liability**.

Regulation	Requires	Affected Controls
ICT Act 2006	Digital security measures	Technical + Legal
GDPR	Data protection by design	All four control types
PCI-DSS	Payment data security	Physical + Technical + Procedural
NDA's / Contracts	Confidentiality obligations	Procedural + Legal

*Technologies and services are often deployed **without the right controls**. Our cyber framework must **detect and respond** to these situations.*

Key Takeaways

- ① Effective cybersecurity requires **all four control types**: Physical, Technical, Procedural, and Legal
- ② **People are the weakest link** — human factors contribute to most security failures
- ③ **Trust is not a control** — procedures must replace trust, especially for privileged access
- ④ **Culture matters** — positive organizational culture correlates with better security
- ⑤ **Social engineering** bypasses technical controls by exploiting human nature
- ⑥ Single point of accountability (**SPOA**) prevents ownership ambiguity
- ⑦ Security awareness training must be **continuous, practical, and updated regularly**

Discussion Questions

- ① Your company has **excellent technical security** (encryption, firewalls, MFA) but no physical security for the server room. How vulnerable are you?
- ② A senior developer with 10 years at the company has **admin access to everything** because “they’ve always been trustworthy.” What procedural controls would you suggest?
- ③ You notice a critical **security vulnerability** in your company’s product, but your manager says “don’t report it — it’ll delay the release.” What do you do?
- ④ How would you **design a security awareness program** for a team of 50 software engineers?